RESTRICTED

QAYRAWAN INFORMATION SYSTEMS

AI Usage Procedure

Procedure · Implementing document for the AI Usage Policy QIS-POL-002

Document ID	**QIS-PRC-002**
Version	0.3 (Draft)
Date	10 November 2026
Classification	Restricted
Sharing signal	Amber · TLP:AMBER

Prepared by Naif Alsalem, GRC Lead

Issued in Arabic and English; if they conflict, the Arabic text prevails. QIS is a fictional company: its people and clients are invented for a professional portfolio by Naif Alsalem. The regulators and regulations cited are real.

RESTRICTED

Document information

Document name	AI Usage Procedure
Document code	QIS-PRC-002
Parent policy	AI Usage Policy — QIS-POL-002 (version 0.5)
Document owner	GRC Lead — Naif Alsalem
Prepared by	Naif Alsalem — GRC Lead
Document version	0.3 (Draft)

Sharing signal (Traffic Light Protocol)

This document is marked under the Traffic Light Protocol (TLP) used in National Cybersecurity Authority documents at **Amber (TLP:AMBER)**. It may not be circulated beyond that level without the owner's approval.

● **Red** TLP:RED	Personal and confidential to the recipient only: it may not be shared with anyone inside or outside the recipient's organization beyond the stated recipients.
● **Amber** TLP:AMBER	**Limited sharing: the recipient may share it within their own organization, only with the people concerned and those who need to act on it. — the level set for this document**
● **Green** TLP:GREEN	Sharing within the same community: it may be shared within the organization, related organizations or the same sector, but not through public channels.
● **White** TLP:WHITE	Unlimited.

RESTRICTED

Change log

Version	Date	Changed by	Reason for change
0.1	9 Nov 2026	Naif Alsalem	First version, after separating the implementing steps from policy QIS-POL-002 and expanding them into five procedures.
0.2	9 Nov 2026	Naif Alsalem	New visual identity and cover, readability, and the four sharing levels used in NCA documents.
0.3	10 Nov 2026	Naif Alsalem	Classification badge centred and coloured by level, watermark coloured, and the company's Arabic name updated. English version translated from the Arabic lead text.

RESTRICTED

Document approval

Role	Job title	Name	Date	Signature
Owner	GRC Lead	Naif Alsalem	—	—
Reviewer	Chief Technology Officer	Reem Al-Otaibi	—	—
Reviewer	Head of Service Delivery	Sultan Al-Dossary	—	—
Approver	Chair, Cybersecurity Steering Committee	Faisal Al-Harbi	—	—

Review schedule

Review frequency	Last review	Next review
With every update to the parent policy, and at least once a year	—	November 2027

RESTRICTED

Document classification

Top Secret	The document is classified "Top Secret" if unauthorized access to it or disclosure of it or its content would cause serious damage that cannot be remedied or repaired.
Secret	The document is classified "Secret" if unauthorized access to it or disclosure of it or its content would cause serious damage. This applies to sensitive information that defines how QIS operates.
Restricted	**The document is classified "Restricted" if unauthorized access to it or disclosure of it or its content would cause limited damage. This applies to information not approved for general circulation outside QIS.**
Public	The document is classified "Public" when unauthorized access to it or disclosure of its content would have no effect on QIS. This applies to documents approved for public release.

Confidentiality of the document

This document is a Qayrawan Information Systems document classified Restricted. It may be circulated only to QIS staff and to the government clients under contract who need to see it. It may not be published, changed or shared, in whole or in part, with anyone unauthorized without the prior written approval of the document owner.

Contents

1. Purpose
2. Scope
3. Relation to the parent policy
4. Roles in carrying out the procedures
5. Procedure map
6. Procedure 1: Request and approve an AI tool or use case
7. Procedure 2: Assess the cybersecurity risk of AI systems
8. Procedure 3: Develop securely and review AI-generated outputs and code
9. Procedure 4: Manage access and permissions for AI tools
10. Procedure 5: Respond to AI incidents and shut down safely
11. What the procedures need to run
12. Compliance indicators
13. References

RESTRICTED

1. Purpose

This document sets out the detailed steps that turn the clauses of the AI Usage Policy into day-to-day work that can be measured and audited: who owns each step, what it must produce, how long it takes, and which records must be kept.

2. Scope

These procedures apply to every QIS department, its staff and contractors, to every AI tool and model used at QIS, and to the AI features QIS builds or hosts for its clients, across the whole life cycle from request and assessment to operation and safe shutdown.

3. Relation to the parent policy

This document comes from the AI Usage Policy QIS-POL-002 and creates no obligations beyond it. Where they conflict, the policy prevails. Each procedure lists the policy clauses it carries out, and definitions are read from the policy rather than repeated here.

4. Roles in carrying out the procedures

Role	Responsibility in these procedures
Cybersecurity Steering Committee	Approves high-impact tools and use cases, accepts residual risks, and follows the quarterly compliance reports.
GRC Lead	Runs these procedures, manages the register of approved tools and the risk register, reviews compliance, and reports and escalates.
Security Operations and Engineering	Assesses risk, runs tests and review gates, reviews access, and leads incident response with the managed security operations centre.
Chief Technology Officer	Applies access, settings and logging, and supports operating and recovery environments.
Development team	Applies secure development requirements and reviews and tests AI-generated code.
Head of Service Delivery	Coordinates with clients, obtains their written approval, and notifies them of incidents.
Requesting departments	Submit complete requests, run pilots, and follow the controls during use.

RESTRICTED

5. Procedure map

The five procedures cover the life cycle of AI use at QIS in this order:

1 Request	2 Assess	3 Develop	4 Operate	5 Respond
Submit, assess and approve the request	Analyze cybersecurity risk	Secure design and output review	Access management and monitoring	Contain incidents and shut down safely

Procedure	Name	Section	Policy clauses
1	Request and approve a tool or use case	6	QIS-9.1.1 · QIS-9.1.2 · QIS-9.2.2 · QIS-2-4-1 · QIS-4-1-1 · 1-2-6
2	Assess cybersecurity risk	7	1-1-1 · 1-1-2 · QIS-1-1-1 to QIS-1-1-3 · 2-6-1 to 2-6-3
3	Secure development and output review	8	Subcomponent 1-2 in full · QIS-1-2-1 to QIS-1-2-3 · 2-7
4	Access and permissions management	9	Subcomponents 2-2 and 1-3 in full
5	Incident response and safe shutdown	10	Subcomponent 2-8 · 3-1-1 · QIS-3-1-1 · QIS-3-1-2

RESTRICTED

6 Procedure 1: Request and approve an AI tool or use case

Policy clauses implemented: QIS-9.1.1, QIS-9.1.2, QIS-9.2.2, QIS-2-4-1, QIS-4-1-1, 1-2-6

Procedure owner	Frequency	Steps	Reference duration
GRC Lead	Every new request	8 steps	About 16 working days

6.1 Objective

To make sure every proposed AI tool or use case goes through one path of request, assessment and approval before it is used, and that the approval decision, its reasons and the highest data classification that may be entered are recorded.

6.2 Frequency and scope

- When any new AI tool or model is requested for QIS.
- When AI is requested for a client's data, or an AI feature is proposed for a client's system.
- When an existing use case is widened or its purpose changes.

6.3 Procedure steps

#	Step	Performed / approved by	Consulted / informed	Output	Time
1	Submit a request covering the tool, purpose, users, the type of data expected to be entered, the non-technical alternative, the expected value and the running cost.	Requesting department Approves: Line manager	GRC	**Request form**	Day 0
2	Screen the request for completeness and log it in the use-case register.	GRC Approves: GRC Lead	Requesting department	**Use-case register entry**	3 working days
3	Assess the provider: where data is processed and hosted, input retention, training on inputs, security controls and contract terms.	GRC Approves: GRC Lead	Chief Financial Officer	**Provider assessment**	5 working days
4	Assess cybersecurity risk under procedure 2 and set the impact level.	SecOps Approves: Security Operations Lead	IT	**Risk assessment report**	In parallel

RESTRICTED

#	Step	Performed / approved by	Consulted / informed	Output	Time
5	Technical review: single sign-on, multi-factor authentication, logging and integration.	Chief Technology Officer Approves: Chief Technology Officer	SecOps	**Technical recommendation**	3 working days
6	Obtain the client's written approval if the request involves a client's data or system.	Service Delivery Approves: Head of Service Delivery	Client · GRC	**Client approval**	Per client
7	Decide: approve with conditions or reject with reasons; high-impact cases are approved by the Steering Committee.	GRC Approves: Steering Committee for high-impact cases	Requesting department	**Recorded decision**	5 working days
8	Add the tool to the register of approved tools with the highest data classification allowed, inform staff, and start a pilot of set scope.	GRC Approves: GRC Lead	All departments	**Updated tool register**	1 day

6.4 Mandatory controls

- No tool is used before it is listed in the register of approved tools.
- Requests whose effect cannot be measured, or whose only reason is to acquire a tool without real use, are rejected.
- No client's data is used without the client's written approval, and it is processed inside the Kingdom.
- A final human decision is kept in every case that affects citizens.

6.5 Records to keep

Request form, provider assessment, risk assessment report, technical recommendation, client approval, recorded decision, updated tool register.

RESTRICTED

7 Procedure 2: Assess the cybersecurity risk of AI systems

Policy clauses implemented: 1-1-1, 1-1-2, QIS-1-1-1 to QIS-1-1-3, 2-6-1 to 2-6-3

Procedure owner	Frequency	Steps	Reference duration
Security Operations and Engineering	On significant change / annually	7 steps	About 16 working days

7.1 Objective

To identify, assess, treat and follow the cybersecurity risks of AI tools and features across every stage of their life cycle, under the methodology in QIS-RMM-001.

7.2 Frequency and scope

- Before any new tool or use case is approved.
- After any significant change to the model, data source or scope of use.
- Within twelve months of the last assessment at the latest.
- As soon as a related vulnerability is found or an incident occurs.

7.3 Procedure steps

#	Step	Performed / approved by	Consulted / informed	Output	Time
1	Set the scope of the assessment: system components, assets, dependencies and the clients affected.	SecOps Approves: Security Operations Lead	GRC	**Scope document**	Day 0
2	Analyze AI-specific threats with STRIDE: prompt injection, data poisoning, model extraction and data leakage.	SecOps Approves: Security Operations Lead	Development	**Threat log**	3 working days
3	Estimate likelihood and impact and set the risk level using the matrix in QIS-RMM-001.	SecOps · GRC Approves: GRC Lead	System owners	**Risk rating**	3 working days
4	Set the required controls and give each an owner and a deadline.	SecOps Approves: Security Operations Lead	IT · Development	**Treatment plan**	5 working days

RESTRICTED

#	Step	Performed / approved by	Consulted / informed	Output	Time
5	Present the residual risks to the risk owner for documented acceptance under the acceptance authority.	Risk owner Approves: Per the risk level in QIS-RMM-001	Steering Committee	**Risk acceptance**	5 working days
6	Record the risks in the risk register QIS-RR-001 under the AI category.	GRC Approves: GRC Lead	Steering Committee	**Updated risk register**	1 day
7	Follow the treatment plan, check its effect and escalate delays.	SecOps Approves: Security Operations Lead	Steering Committee	**Follow-up report**	Quarterly

7.4 Mandatory controls

- Reassessment is required after any significant change, without waiting for the annual cycle.
- AI features are disabled or restricted when a vulnerability is found, until the fix is verified.
- Missing a treatment deadline is non-compliance and is escalated to the policy owner.
- No use in a client system goes live before residual risks are accepted.

7.5 Records to keep

Scope document, threat log, risk rating, treatment plan, risk acceptances, follow-up reports.

RESTRICTED

8 Procedure 3: Develop securely and review AI-generated outputs and code

Policy clauses implemented: Subcomponent 1-2 in full, QIS-1-2-1 to QIS-1-2-3, 2-7

Procedure owner	Frequency	Steps	Reference duration
Chief Technology Officer	Every project or release	7 steps	Project life cycle

8.1 Objective

To make sure secure design is applied in projects that involve AI, and that AI-generated code and outputs are reviewed before they are used in client systems.

8.2 Frequency and scope

- Client projects with an AI feature in scope.
- Projects that use coding assistants or AI tools during development.
- Every release that changes the model, prompts or knowledge sources of an existing feature.

8.3 Procedure steps

#	Step	Performed / approved by	Consulted / informed	Output	Time
1	Set cybersecurity requirements at planning and include them in the project documents.	Development · SecOps Approves: Chief Technology Officer	Service Delivery	**Requirements document**	Before development
2	Check data sources and their trustworthiness, and validate and sanitize external inputs.	Development Approves: Chief Technology Officer	GRC	**Data source report**	Analysis stage
3	Peer review, security scan and dependency scan for all AI-generated code in the build pipeline.	Development Approves: Development Lead	SecOps	**Scan results**	Before merging
4	Run cybersecurity tests and the feature's guardrails and check they work.	SecOps Approves: Security Operations Lead	Development	**Test report**	Before deployment
5	Security review gate at the end of each stage, recording the approve or reject decision and its reasons.	SecOps Approves: Security Operations Lead	Project manager	**Gate decision**	End of each stage

RESTRICTED

#	Step	Performed / approved by	Consulted / informed	Output	Time
6	Obtain the client's written approval to add the feature to its system.	Service Delivery Approves: Head of Service Delivery	Client	**Client approval**	Before deployment
7	Approve the move to production, and record the handover file and the run and rollback plan.	Chief Technology Officer Approves: Chief Executive Officer	Steering Committee · client	**Handover file**	5 working days

8.4 Mandatory controls

- No AI-generated code is merged into a client repository without review and scanning.
- Real client data may not be used in development environments unless anonymized and approved by the client.
- Models may not be retrained in the live environment without documented controls and justification.
- Data returned from external tools and APIs is treated as untrusted.

8.5 Records to keep

Requirements document, data source report, scan results, test reports, gate decisions, client approval, handover file.

RESTRICTED

9 Procedure 4: Manage access and permissions for AI tools

Policy clauses implemented: Subcomponents 2-2 and 1-3 in full

Procedure owner	Frequency	Steps	Reference duration
Chief Technology Officer	Every access request	7 steps	About 3 working days

9.1 Objective

To make sure access to AI tools and their components is limited to authorized users, services and agents, on least privilege.

9.2 Frequency and scope

- When a user, service or AI agent account is created.
- When a job role changes or a contract ends.
- Periodic review of identities, permissions and keys.

9.3 Procedure steps

#	Step	Performed / approved by	Consulted / informed	Output	Time
1	Submit the access request, stating the tool, level, reason and period.	Line manager Approves: Tool owner	—	**Access request**	On request
2	Confirm the policy training is complete, and check need-to-know and segregation of duties.	Tool owner Approves: Security Operations Lead	GRC	**Documented approval**	1 day
3	Grant access through single sign-on and enable multi-factor authentication.	IT Approves: Chief Technology Officer	Tool owner	**Proof of completion**	1 day
4	Link every AI agent account to an accountable human owner and record it in the asset register.	Development Approves: Chief Technology Officer	SecOps	**Account register**	On creation
5	Manage API keys in the secrets vault: issue, rotate, and revoke at once on suspicion.	IT Approves: Chief Technology Officer	SecOps	**Key register**	Every 90 days

RESTRICTED

#	Step	Performed / approved by	Consulted / informed	Output	Time
6	Review identities, permissions, service accounts and keys periodically.	SecOps Approves: Security Operations Lead	Tool owners · GRC	**Review report**	Quarterly
7	Remove all access at once when a contract ends or a role changes.	HR · IT Approves: Chief Financial Officer	SecOps	**Proof of removal**	Within 24 hours

9.4 Mandatory controls

- Shared or ownerless accounts may not be used with AI tools.
- Rate limits and usage thresholds are applied to reduce the risks of model extraction and data leakage.
- Records of removed accounts are not deleted, and are kept for the approved retention periods.
- Staff with privileged access to AI environments are security screened.

9.5 Records to keep

Access requests and approvals, account register, key register, periodic review reports, proof of removal.

RESTRICTED

10 Procedure 5: Respond to AI incidents and shut down safely

Policy clauses implemented: Subcomponent 2-8, 3-1-1, QIS-3-1-1, QIS-3-1-2

Procedure owner	Frequency	Steps	Reference duration
Security Operations and Engineering	When an incident occurs	8 steps	Contained within 4 hours

10.1 Objective

To detect, contain, treat and recover from AI-related cybersecurity incidents early, and record the lessons learned, within the Incident Response Plan QIS-IRP-001.

10.2 Frequency and scope

- Client data or personal data entered into an unapproved tool.
- Data leaking through prompts or outputs, or malicious prompt injection.
- Unusual behaviour in an AI feature's outputs or an agent's actions in a client system.
- Failure of an AI feature that supports a client's core service.

10.3 Procedure steps

#	Step	Performed / approved by	Consulted / informed	Output	Time
1	Detect the event through the managed security operations centre or a report from staff or the client, and log it.	SecOps Approves: Security Operations Lead	GRC	**Incident log**	Hour 0
2	Rate the severity under section 5 of QIS-IRP-001.	Incident lead Approves: Incident lead	Chief Technology Officer	**Severity rating**	Within 1 hour
3	Contain it: disable or restrict the feature, revoke affected keys and sessions, and preserve evidence.	SecOps · IT Approves: Incident lead	Development	**Containment actions**	Within 4 hours
4	Notify the affected client, and notify the controller of any personal data leak so it can notify SDAIA within 72 hours.	Service Delivery · data protection officer Approves: Incident lead	Chief Executive Officer	**Documented notices**	Per QIS-IRP-001

#	Step	Performed / approved by	Consulted / informed	Output	Time
5	Roll back to the last approved version or shut down safely, and switch to the manual alternative if needed.	IT Approves: Chief Technology Officer	Service Delivery	**Recovery log**	Per recovery time
6	Remove the root cause and test the fix before restarting.	Development · SecOps Approves: Security Operations Lead	GRC	**Fix report**	5 working days
7	Reassess the risk under procedure 2 and update the risk register.	GRC Approves: GRC Lead	Steering Committee	**Updated risk register**	5 working days
8	Hold a lessons-learned session and close the incident.	Incident lead Approves: Incident lead	Steering Committee	**Closure report**	10 working days

10.4 Mandatory controls

- Evidence is preserved before any action that could destroy it.
- The feature is not restarted before the fix is verified and the restart approved.
- Entering client data into an unapproved tool is a data incident, reported within its time limits.
- Incident records are kept for at least twelve months.

10.5 Records to keep

Incident log, severity rating, containment and evidence log, notices, recovery log, fix report, closure report.

RESTRICTED

11. What the procedures need to run

11.1 Systems and tools

Tool / system	Purpose	Procedures
Register of approved tools and use cases	Records requests, decisions and the classification allowed for each tool	1, 2
Risk register QIS-RR-001	Records AI risks and follows their treatment	2, 5
Build pipeline with security and dependency scanning	Scans generated code before merging	3
Single sign-on and secrets vault	Manage identities and keys	4
Data loss prevention and destination allow-list	Stop data being sent to unapproved services	1, 5
Managed security operations centre	Monitors logs and incidents	5

11.2 Approvals matrix

Decision	Approved by
Approving a tool that will not receive client data	GRC Lead with the Chief Technology Officer
Approving the use of AI on a client's data	Steering Committee, after the client's written approval
Adding an AI feature to a client system	Chief Executive Officer, after the client's written approval
Accepting residual risk	By risk level, under the acceptance authority in QIS-RMM-001
Restarting a feature after an incident	Incident lead with the Chief Technology Officer

RESTRICTED

12. Compliance indicators

Code	Indicator	Target	Procedure
PRC-01	Requests completed within the reference time of procedure 1	90%	1
PRC-02	AI tools with a current risk assessment	100%	2
PRC-03	Generated code that passed scanning before merging	100%	3
PRC-04	Access removed within 24 hours of a relationship ending	100%	4
PRC-05	AI incidents contained within 4 hours	95%	5

13. References

Type	Code	Reference
Internal	QIS-POL-002	AI Usage Policy (parent policy)
Internal	QIS-RMM-001	Risk Management Methodology
Internal	QIS-RR-001	Risk Register
Internal	QIS-IRP-001	Incident Response Plan
Internal	QIS-BCP-001	Business Continuity Plan
External	AICG-1:2026	AI Cybersecurity Guidelines — National Cybersecurity Authority
External	PDPL	Personal Data Protection Law and its implementing regulation

RESTRICTED